

Prevention and Monitoring recommendations

Carin Madden
PNC CyberBootcamp 2026
September 10, 2026

Executive Summary

On September 2, 2026, suspicious activity was detected on the Meridian Trust Bank web server, MTB-WEB01. The alert showed that a process called apache-worker was making an outbound connection to the external IP address 185.220.101.47 on port 8443 every five minutes. After reviewing the evidence, I determined that an attacker was able to gain access through the web server, escalate their privileges from www-data to root, and create multiple ways to maintain access to the system. The server was isolated from the network at 10:05 UTC but was kept powered on so important evidence could be collected before it disappeared.

Evidence Handling

The first step of the investigation was preserving the evidence on MTB-WEB01. The computer was isolated from the network but was not immediately powered off. This was important because some evidence is volatile, meaning it could disappear if the computer was shut down or restarted. Examples include running processes, active network connections, logged-in users, and open files.

The evidence was collected by first capturing the running processes, followed by network connections, logged-in users and login history, open network files, and scheduled tasks. After the volatile evidence was preserved, a disk image was acquired.

During the volatile capture, I found a suspicious process called apache-worker running as root. It had an established connection from the server at 10.50.2.24 to 185.220.101.47 on port 8443. The login history also showed that root had previously logged in from the same external IP address. A cron job was also found that ran /usr/local/bin/apache-worker every five minutes as root.

After the volatile evidence was collected, the disk was acquired at 10:31 UTC. SHA-256 hashes were recorded so the evidence could later be checked to make sure it had not been changed.

Evidence	SHA-256 Hash
----------	--------------

/var/www/html/uploads/style.php	
---------------------------------	--

	2dfc22e2fb93187b7537d9ffec52ecc94fd6416c84b78e68ff7a025e975c20c
--	---

/usr/local/bin/apache-worker	
------------------------------	--

	1ebcce99569f4337f9ee3746b7b095a9f54abfe3036ef06014b1a00ea4d15d4b
--	--

/etc/cron.d/apache-logrotate	
------------------------------	--

	d9bc0ee387921dcaedfc87de4a72ec42e45cf268adb2777d5b014375417cb9cc
--	--

/etc/passwd	0243860670744531f70b46cfb844a66eb8ca0de0e4b7b15dff991b3960577295
-------------	--

I also tested how hashing detects changes by changing one character in an evidence block. Even though I only changed one character, only 3 characters in the entire SHA-256 hash stayed the same. This showed why hashes are useful in digital forensics. If the hash calculated later matches the hash taken when the evidence was collected, it provides strong evidence that the file has not been changed.

Incident Timeline

I created the following timeline by comparing the Apache logs, authentication logs, system logs, file-system timeline, and recovered files.

Time (UTC)	Event	Evidence Source	Confidence
02:08:14	185.220.101.47 began scanning the web server using Nmap.	Apache access log	Inferred
02:12:33	The attacker used a path traversal request to access /etc/passwd. The server returned a 200 status code.	Apache access log	Inferred
02:15:22	The suspicious style.php file was created in the uploads directory while the attacker was also sending commands through /bin/sh.	Timeline and Apache log	Confirmed
02:17:40	The attacker began making POST requests to /uploads/style.php.	Apache log and recovered file	Confirmed
02:20:47	The www-data account used pkexec and obtained a root session.	Authentication log	Confirmed
02:23:11	A new account called svc-backup was created with UID 0, giving it root-level privileges.	Authentication log, timeline, Bash history	Confirmed
02:24:48	A root SSH authorized key was created and root successfully logged in from 185.220.101.47.	Authentication log, timeline, SSH key	Confirmed
02:25:57	/usr/local/bin/apache-worker was created and made executable.	Timeline and Bash history	Confirmed
02:26:30	/etc/cron.d/apache-logrotate was created to run apache-worker every five minutes.	Timeline, system log, Bash history	Confirmed
02:34:55	The attacker used /tmp/.ICE-unix while creating an archive of /var/www/html/data.	Timeline and Bash history	Confirmed
02:41:19	The attacker attempted to clear command history. Root's history was still recoverable.	Timeline and Bash history	Confirmed
09:47:12	The SOC detected the repeated outbound connection and generated the security alert.	SOC alert and volatile evidence	Confirmed

Looking at all of these events together helped me understand the attack instead of looking at each log separately. The attacker first scanned the server, exploited the web server, gained command execution, escalated to root, created persistence, and then maintained communication with the external IP address.

Root Cause

The first part of the attack appears to have been the vulnerability from my Day 1 assessment identified as MTB-0001, CVE-2021-42013. This vulnerability involved Apache and allowed the attacker to use path traversal.

One of the strongest pieces of evidence was this request:

```
GET /cgi-bin/./%2e/./%2e/./%2e/./%2e/etc/passwd
```

The request returned a 200 status code, meaning that the request succeeded and the server returned content. The attacker then used similar requests against /bin/sh, which allowed them to continue the attack.

After gaining access through the web server, the attacker was operating as the unprivileged Apache account www-data. They then escalated their privileges to root using pkexec/Polkit. This was a vulnerability that was in the assessment and is in the assessment report. The finding ID is MTB-0003 and was reprioritised at 2nd most critical vulnerability because it allowed escalation of privileges.

The authentication log shows:

```
Sep 2 02:20:47 mtb-web01 pkexec[1207]: pam_unix(polkit-1:session): session opened for user root(uid=0) by (uid=33)
```

It then shows:

```
Sep 2 02:21:05 mtb-web01 pkexec[1207]: www-data: Executing command [USER=root]  
[TTY=unknown] [CWD=/var/www/html/uploads] [COMMAND=/bin/sh]
```

These lines are important because UID 33 belongs to www-data, while UID 0 is root. This shows the web-server account successfully opening a root session and executing /bin/sh as root.

After getting root access, the attacker installed three different persistence mechanisms. The first was the svc-backup account, which was created with UID 0. This would survive a reboot and would still exist if the malicious process was killed.

The second was an SSH public key added to root's authorized_keys. This would survive a reboot and a password change because the attacker could authenticate using their SSH key instead of the account password.

The third was the cron job /etc/cron.d/apache-logrotate. This executed /usr/local/bin/apache-worker every five minutes as root. This means that if the apache-worker process was killed, cron could start it again. The cron job would also remain after a reboot.

Indicators of Compromise

The following IOCs were found while reviewing the logs, timeline, recovered files, and volatile evidence.

Type	Indicator	Why It Is Suspicious
IP Address	185[.]220[.]101[.]47	External IP connected to the attack, root login, and outbound traffic
IP/Port	185[.]220[.]101[.]47:8443	apache-worker communicated with this destination
Process	apache-worker	Unknown process running as root
File Path	/var/www/html/uploads/style.php	Suspicious PHP/webshell artifact
File Path	/usr/local/bin/apache-worker	Suspicious executable installed by attacker
File Path	/etc/cron.d/apache-logrotate	Persistence mechanism that runs apache-worker
File Path	/root/.ssh/authorized_keys	Contains the attacker's SSH public key
Account	svc-backup	Unauthorized account created with UID 0
Account	root	Logged into remotely from the suspicious external IP
SSH Key Label	attacker@blackfin	Label attached to the suspicious SSH public key

Recommendations

Patching

The vulnerable software that allowed the attacker to gain access and escalate their privileges should be patched. Apache should be updated so that it is no longer vulnerable to the issue identified in MTB-0001, and MTB-0003 should also be updated to address the privilege escalation vulnerability.

Meridian Trust Bank should also improve its patch management process. These vulnerabilities were already known before this incident occurred. Internet-facing systems such as MTB-0001 and MTB-0003 should receive a higher priority for patching because attackers can access them directly.

Configuration

The Apache configuration should be hardened so users cannot access files outside of the directories they are supposed to access. The specific Apache settings identified earlier in the vulnerability assessment should be changed to prevent the path traversal vulnerability from being successfully exploited.

Detection and Monitoring

I would also recommend better endpoint monitoring. The attacker began compromising the system during the 02:00 hour, but the SOC alert was not generated until 09:47 UTC. This means the attacker was able to remain on the system for more than seven hours before being detected.

Alerts should be created for unusual events such as a new UID 0 account being created, changes to /root/.ssh/authorized_keys, new cron jobs, and unknown executables being added to /usr/local/bin. There should also be an alert if an account such as www-data uses pkexec to become root or starts a shell.

If these events were being monitored, the attack could have potentially been detected around 02:20–02:26 UTC instead of 09:47 UTC. This could have shortened the detection time by approximately seven hours.

Conclusion

From this investigation, I determined that MTB-WEB01 was successfully compromised and that the attacker was able to gain root access. The attacker started by exploiting the web server, escalated from www-data to root, and then created a backdoor account, an SSH key, and a cron job to maintain access.

This investigation showed me how important it is to look at multiple types of evidence during a cybersecurity investigation. A single log did not explain everything that happened, but putting together the network connections, authentication logs, file timeline, running processes, and

recovered files made it possible to understand how the attack happened and what the attacker did after gaining access.

Disclaimer: ChatGPT was used to reword sentences and for formatting of this report.